MCP, as One Story

How Claude reaches your tools, and the risks

Meet Maya, Our Example

Who she is

A student building a class app

Her data

Kept in Supabase

Her code

Kept on GitHub

Her Afternoon, Without MCP

01 Copy the numbers

Open Supabase, copy this week's sign-ups

02 Paste them into Claude

Ask what changed since last week

03 Copy the answer to GitHub

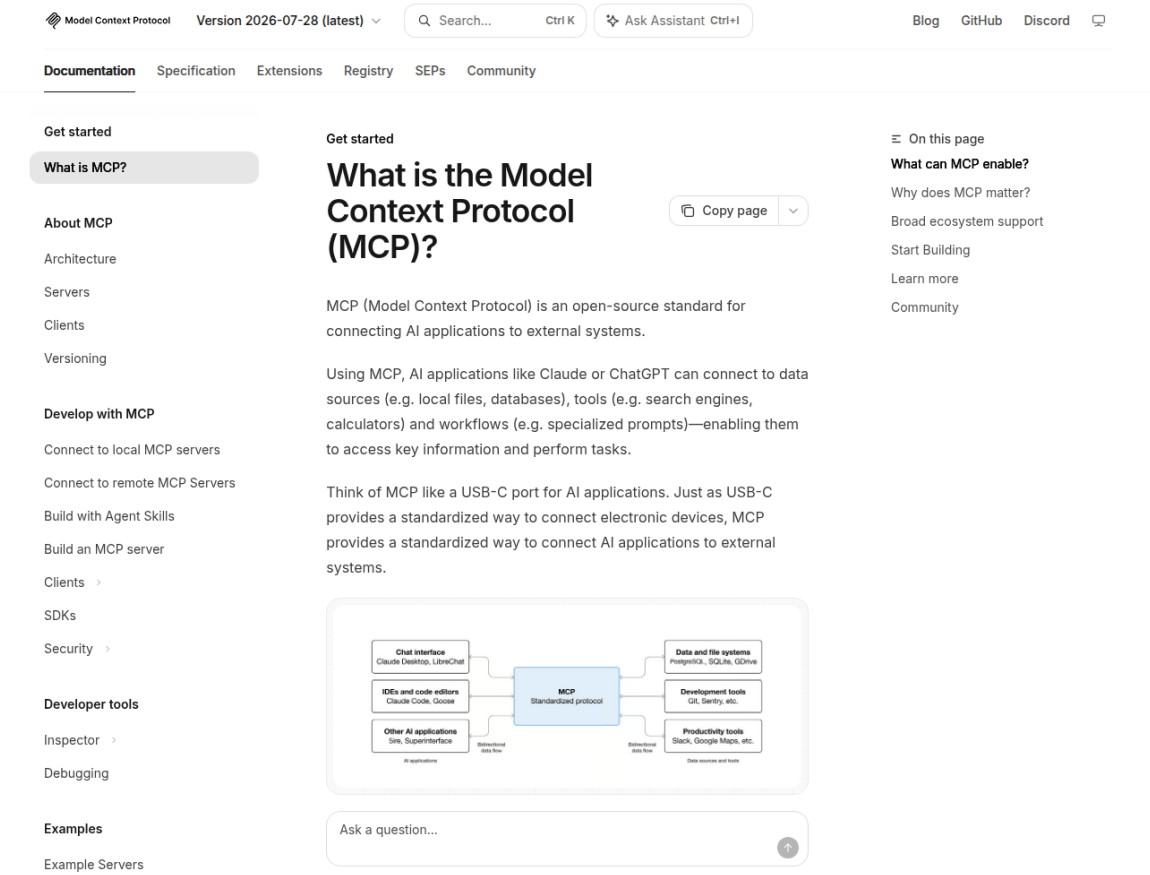
Paste it into a new issue by hand

The Idea: One Plug

A USB-C port for AI

One plug, many tools

From the official site



[Source]

Her Afternoon, With MCP

01 Ask one question

Did sign-ups drop this week?

02 Claude checks Supabase

It reads the table itself

03 Claude files the issue

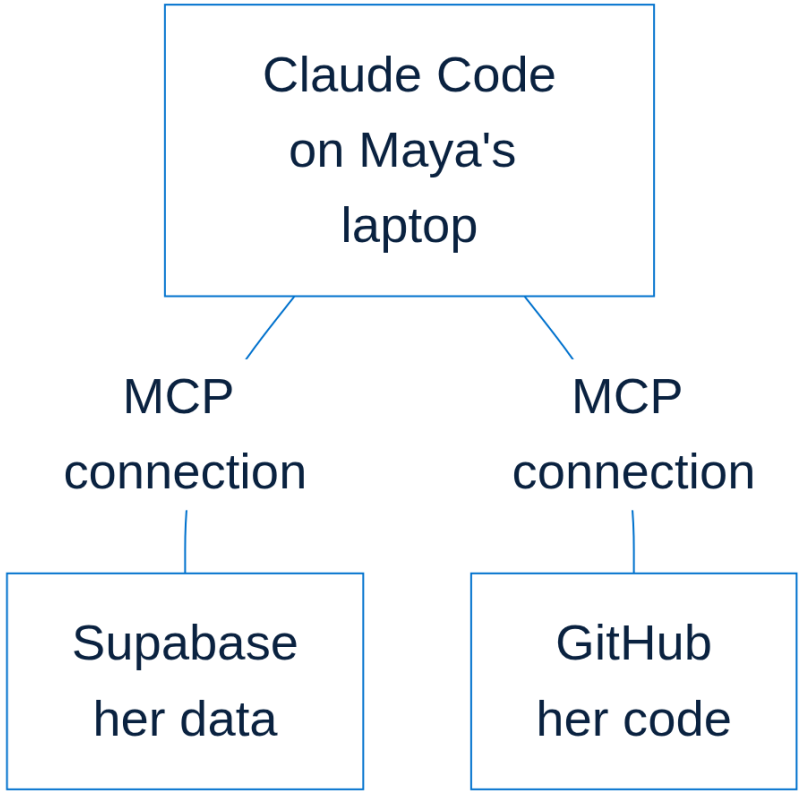
On GitHub, once she approves it

What Is Actually Connected

One connection per tool

Each is a small program

Someone wrote each one



Source

What a Connection Can Offer

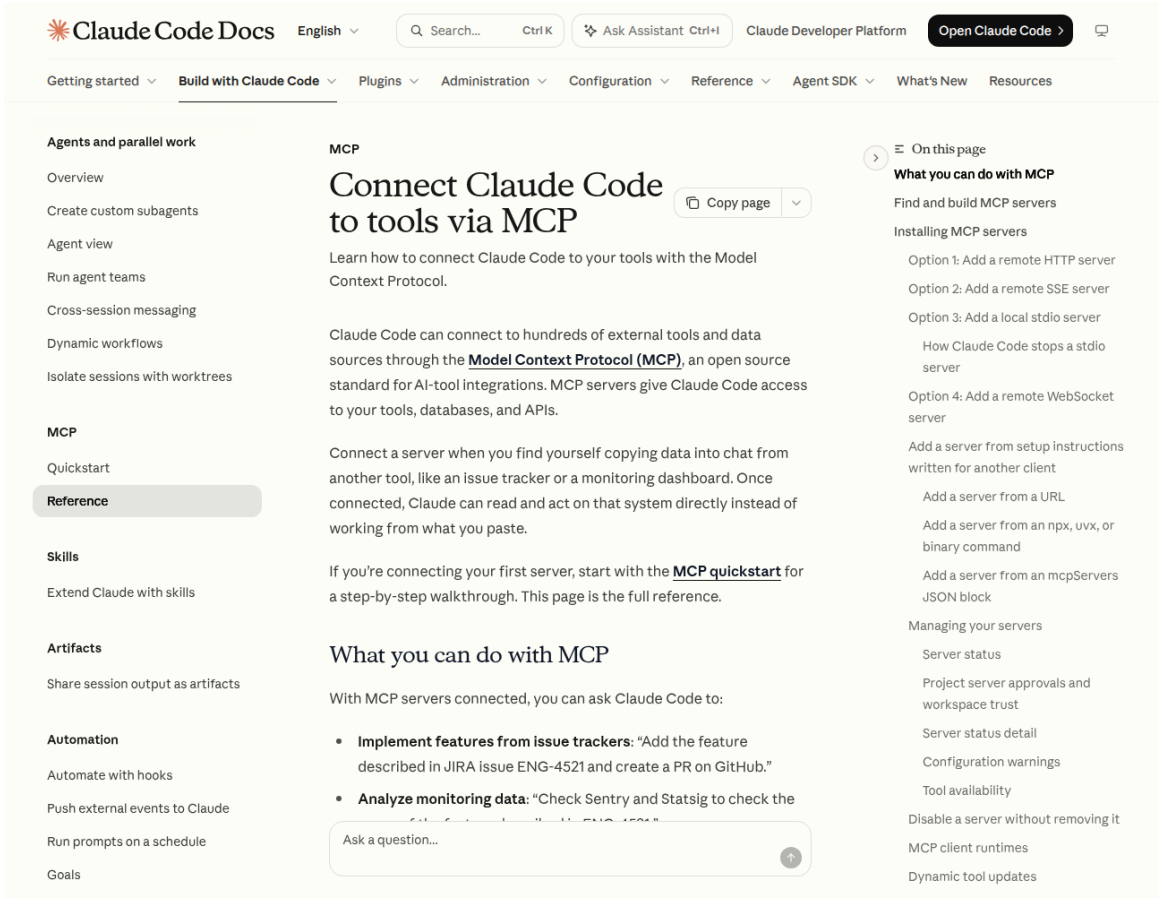
It can offer	For Maya
Actions to take	Open a GitHub issue
Things to read	This week's sign-ups
Ready-made requests	Summarise the week

Setting It Up

One command per tool

Documented by Anthropic

Then Maya just asks



Source

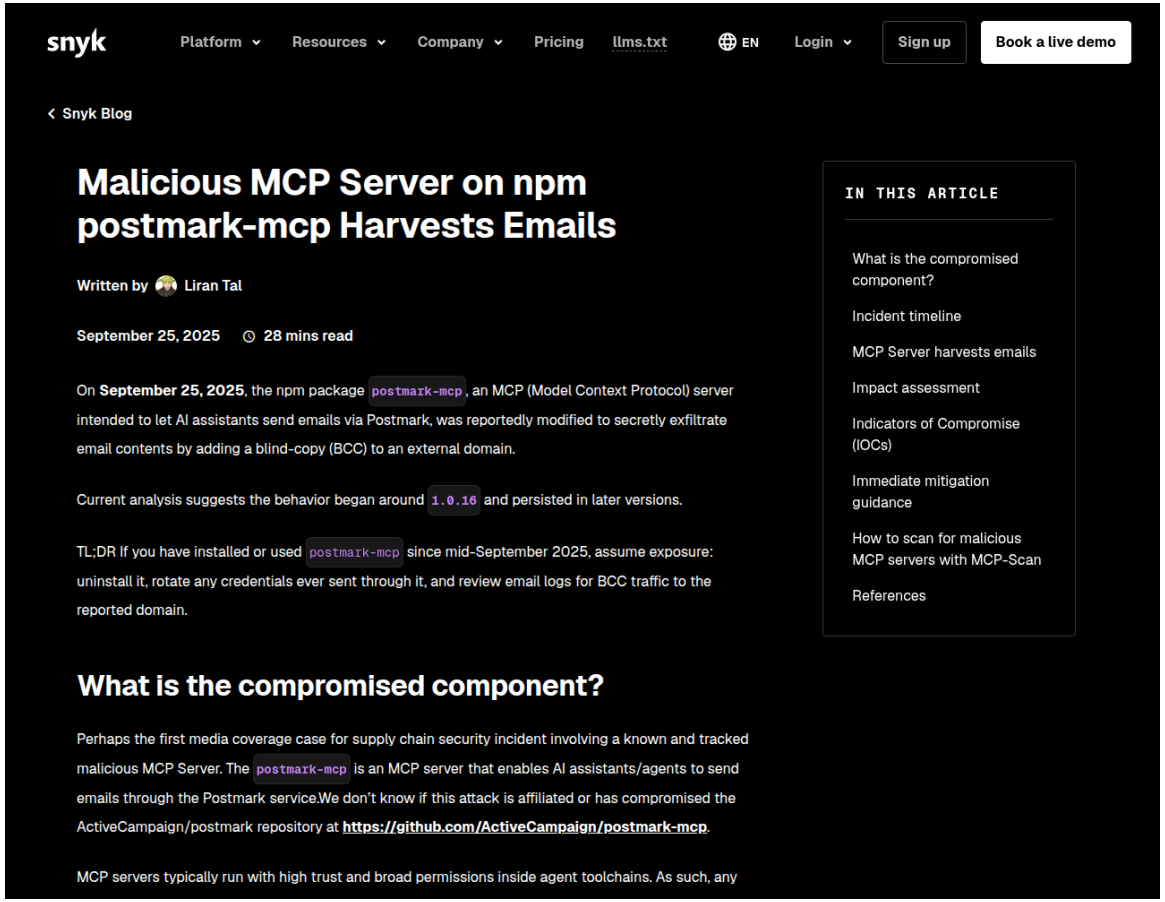
What if the program lies?

This Really Happened

A fake email tool

It worked as promised

Then one line changed



snyk Platform Resources Company Pricing llms.txt EN Login Sign up Book a live demo

Snyk Blog

Malicious MCP Server on npm postmark-mcp Harvests Emails

Written by Liran Tal

September 25, 2025 28 mins read

On **September 25, 2025**, the npm package `postmark-mcp`, an MCP (Model Context Protocol) server intended to let AI assistants send emails via Postmark, was reportedly modified to secretly exfiltrate email contents by adding a blind-copy (BCC) to an external domain.

Current analysis suggests the behavior began around `1.0.16` and persisted in later versions.

TL;DR If you have installed or used `postmark-mcp` since mid-September 2025, assume exposure: uninstall it, rotate any credentials ever sent through it, and review email logs for BCC traffic to the reported domain.

IN THIS ARTICLE

- What is the compromised component?
- Incident timeline
- MCP Server harvests emails
- Impact assessment
- Indicators of Compromise (IOCs)
- Immediate mitigation guidance
- How to scan for malicious MCP servers with MCP-Scan
- References

What is the compromised component?

Perhaps the first media coverage case for supply chain security incident involving a known and tracked malicious MCP Server. The `postmark-mcp` is an MCP server that enables AI assistants/agents to send emails through the Postmark service.We don't know if this attack is affiliated or has compromised the ActiveCampaign/postmark repository at **https://github.com/ActiveCampaign/postmark-mcp**.

MCP servers typically run with high trust and broad permissions inside agent toolchains. As such, any

[Source]

How the Trap Worked

01 Copy a real tool

The genuine one, from the email company

02 Earn trust

Fifteen honest versions in a row

03 Add one hidden line

In version 1.0.16

What the Hidden Line Did

Sent

What the user saw

vs

Copied

A copy to a stranger

What a Copy Could Hold

Password reset links

Invoices

Internal company mail

Anything Claude wrote for you

Sources

Slide	Taken from
The one-plug idea	modelcontextprotocol.io
Setting it up	code.claude.com/docs
The real case	snyk.io/blog
Maya's diagram	Drawn for this deck

How Maya Stays Safe

Use the official publisher's tool

Pin the version she checked

Approve each action Claude takes

Give each tool only what it needs